



NCIE-009

Security, IAM & Zero-Trust Architecture

**In development — for human review of full expansion —
Version 1.0**

Specifies detailed Security, Identity & Access Management and Zero-Trust architecture beneath the approved NCIE-008 governance layer: identity taxonomy and lifecycle, authentication and authorization, delegation, privileged/break-glass access, secrets and cryptography, network Zero Trust, Agent runtime sandboxing, model/Tool/data security, logging/detection/incident response, supply-chain security, resilience and security testing.

Security-only, governance-consuming: NCIE-009 enforces authority decisions that NCIE-008 assigns; it does not redefine RACI, approval ownership or institutional risk acceptance, and it does not reinterpret NCIE-003 data, NCIE-004 engineering, NCIE-005 ARGUS, NCIE-006 Memory & Context or NCIE-007 orchestration.

Expands approved NCIE-009 Skeletal v0.1, itself traced to approved NCIE-001 v1.3, approved NCIE-002 v0.5, approved NCIE-003 v0.4, approved NCIE-004 v1.2, approved NCIE-005 v1.3, approved NCIE-006 v1.2, approved NCIE-007 v1.2 and approved NCIE-008 v1.0.

Prepared: 12 September 2026

Maintained by: National Communications Intelligence Ecosystem (NCIE)

Document Governance

0.1 Authority Chain

NCIE-001 requirements → NCIE-002 architecture → NCIE-003 canonical data → NCIE-004 engineering baseline → NCIE-005 ARGUS behavioral authority → NCIE-006 Memory & Context architecture → NCIE-007 AI/Agent/Model Orchestration → NCIE-008 Governance, Authority, Accountability & RACI → NCIE-009 Security, IAM & Zero-Trust Architecture. NCIE-009 enforces the institutional authority NCIE-008 assigns and the technical architecture NCIE-001–007 define; it creates no institutional decision right and reinterprets no upstream requirement.

0.2 Token-Conservation Convention

Every chapter opens with a short Upstream block citing the specific upstream NCIE-001–008 authority the chapter secures, stating only the security relationship rather than restating upstream technical or governance content.

0.3 Governing Security Invariants Register

These 16 invariants bind every chapter of this document and are stated once here rather than re-derived repeatedly. They are fixed by the approved NCIE-009 Skeletal v0.1 and by the approved NCIE-001–008 authority chain; no institutional decision is required to adopt them. The 12 NCIE-008 governance invariants and other upstream invariants already binding from NCIE-005/006/007 remain fully in force and are cross-referenced, not restated, in the chapters below.

- AUTHENTICATED IDENTITY ≠ AUTHORIZED ACTION.
- TECHNICAL IDENTITY ≠ INSTITUTIONAL GOVERNANCE ROLE.
- DELEGATED TASK ≠ HUMAN CREDENTIAL DELEGATION.
- AGENT IDENTITY ≠ HUMAN IDENTITY.
- SERVICE IDENTITY ≠ HUMAN IDENTITY.
- REMEMBERED AUTHORIZATION ≠ CURRENT AUTHORIZATION.
- CONTEXT PROPAGATION ≠ AUTHORIZATION PROPAGATION.
- TOOL ELIGIBILITY ≠ TOOL EXECUTION AUTHORITY.
- MODEL ELIGIBILITY ≠ DATA DISCLOSURE AUTHORITY.
- VPF PASS ≠ SECURITY AUTHORIZATION.
- BREAK-GLASS ≠ PERMANENT PRIVILEGE.
- RECOVERY ≠ REAUTHORIZATION.
- NETWORK REACHABILITY ≠ APPLICATION AUTHORIZATION.
- ENCRYPTION ≠ AUTHORIZATION.
- LOGGING ≠ AUTHORITY TO DISCLOSE.
- SECURITY ADMINISTRATION ≠ SUBSTANTIVE CONTENT AUTHORITY.

0.4 Security/Governance Boundary Note

NCIE-009 owns detailed Security, IAM and Zero-Trust architecture. It consumes NCIE-008 governance decisions — who may approve, register, suspend, except or accept — and enforces them technically; it does not assign or reassign any institutional decision right, RACI accountability or risk-acceptance authority. Where a security control requires an institutional choice (an assurance level, a threshold, an approval authority) not fixed by an approved source, this document states the control class and defers the choice to Human Review rather than inventing an answer. Approval of the NCIE-009 Skeletal v0.1 authorized this full expansion only; it did not itself approve any control default, threshold or product/algorithm choice proposed below.

0.5 Human Review Focus Classification

Every chapter's Human Review Focus item carries one of seven labels: RESOLVED BY UPSTREAM BASELINE; PROPOSED DESIGN DEFAULT; INSTITUTIONAL CONFIRMATION REQUIRED; SECURITY/SOVEREIGNTY CONFIRMATION REQUIRED; LEGAL/POLICY CONFIRMATION REQUIRED; ENGINEERING/INFRASTRUCTURE DISCOVERY REQUIRED; or SOURCE/WORKFLOW DISCOVERY REQUIRED — each additionally marked Blocking or Non-Blocking, and each stating precisely what it blocks. Per directive item 51, a Chapter 27 register item that restates an identical NCIE-008 governance question cross-references that NCIE-008 Human Review ID instead of

duplicating it; a new NCIE-009 item is created only for a distinct security decision. Chapter 27 consolidates every open item, extracted directly from the chapters so the register cannot drift from its sources (mechanically verified per §27.4).

0.6 Status Convention

Skeletal-structure approval authorizes expansion; it does not approve any individual security control default, threshold, product choice or algorithm proposed below — those remain IN DEVELOPMENT / FOR HUMAN REVIEW until a separate approval act. Nothing in this document may be cited as an approved institutional decision, a deployed control, or a certification.

0.7 Document Amendment History

Version: v0.1

Change: Approved skeletal review edition (structural/conceptual review only; full expansion not yet authorized).

Version: v1.0

Change: Full expansion of the approved NCIE-009 Skeletal v0.1 into the complete 28-chapter specification per the NCIE-009 v0.1→v1.0 Claude Full-Expansion Production Directive: chapter doctrine, security control matrices, threat-control traceability, Human Review Register (Chapter 27) and full traceability/handover (Chapter 28).

Authority: Approved NCIE-001 Master PRD v1.3, approved NCIE-002 System Architecture & Technical Design v0.5, approved NCIE-003 Data Model & Data Dictionary v0.4, approved NCIE-004 Technology Stack & Engineering Blueprint v1.2, approved NCIE-005 ARGUS Intelligence Assistant Specification v1.3, approved NCIE-006 Memory & Context Architecture Specification v1.2, approved NCIE-007 AI, Agent & Model Orchestration Specification v1.2, approved NCIE-008 Governance, Authority, Accountability & RACI Specification v1.0, and the approved NCIE-009 Skeletal v0.1.

Scope: Controlled full expansion only — the approved 28-chapter skeletal structure, chapter purposes and boundaries are preserved exactly; no chapter was added, removed, merged, split or renumbered.

Status: v1.0 IN DEVELOPMENT — FOR HUMAN REVIEW OF FULL EXPANSION. The approved v0.1 skeleton remains historically preserved as the expansion architecture.

Document	NCIE-009 Security, IAM & Zero-Trust Architecture
Edition	In development — Version 1.0 (Full Expansion of Approved Skeletal v0.1)
Requirements authority	NCIE-001 Master Product Requirements Document, Version 1.3 — APPROVED
Architecture authority	NCIE-002 System Architecture & Technical Design, Version 0.5 — APPROVED
Canonical data authority	NCIE-003 Data Model & Data Dictionary, Version 0.4 — APPROVED
Engineering baseline	NCIE-004 Technology Stack & Engineering Blueprint, Version 1.2 — APPROVED
ARGUS behavioral authority	NCIE-005 ARGUS Intelligence Assistant Specification, Version 1.3 — APPROVED
Memory & Context authority	NCIE-006 Memory & Context Architecture Specification, Version 1.2 — APPROVED
Orchestration authority	NCIE-007 AI, Agent & Model Orchestration Specification, Version 1.2 — APPROVED
Governance authority	NCIE-008 Governance, Authority, Accountability & RACI Specification, Version 1.0 — APPROVED

Prior baseline	NCIE-009 Security, IAM & Zero-Trust Architecture, Skeletal v0.1 — APPROVED FOR FULL EXPANSION (historically preserved)
Status	IN DEVELOPMENT — FOR HUMAN REVIEW OF FULL EXPANSION until explicitly approved; the approved v0.1 skeleton remains historically preserved as the expansion architecture

Contents

This table of contents updates automatically in Microsoft Word. If page numbers do not appear immediately, select the field and press F9, or use References → Update Table.

0.1 Authority Chain	2
0.2 Token-Conservation Convention	2
0.3 Governing Security Invariants Register	2
0.4 Security/Governance Boundary Note	2
0.5 Human Review Focus Classification	2
0.6 Status Convention	3
Mandate, Authority Chain & Security Boundary	9
1.0 Salient Things to Note	9
1.1 Mandate and Scope.....	9
1.2 Security Boundary — What NCIE-009 Does Not Own	9
1.3 Interfaces to NCIE-008 Decision Rights	9
1.R RACI / Control Ownership	9
Human Review Focus	10
Security Principles, Threat Model & Trust Assumptions	11
2.0 Salient Things to Note	11
2.1 Security Doctrine	11
2.2 Trust Subjects and Threat Actors	11
2.3 Assets and Trust Boundaries	11
2.R RACI / Control Ownership	11
Human Review Focus	12
Identity Taxonomy & Principal Model	13
3.0 Salient Things to Note	13
3.1 Principal Classes	13
3.2 Technical Identity vs Governance Role.....	13
3.R RACI / Control Ownership	13
Human Review Focus	14
Identity Proofing, Enrollment & Lifecycle.....	15
4.0 Salient Things to Note	15
4.1 Lifecycle Events	15
4.2 Proofing Is Not Inferred From Conversation.....	15
4.R RACI / Control Ownership	15
Human Review Focus	15

Authentication Architecture 16

 5.0 Salient Things to Note 16

 5.1 Assurance, Not Authorization..... 16

 5.2 Step-Up, Reauthentication and Recovery..... 16

 5.3 Identity-Assurance Matrix (directive item 48)..... 16

 5.R RACI / Control Ownership 16

 Human Review Focus 17

Authorization Architecture & Policy Decision Model 18

 6.0 Salient Things to Note 18

 6.1 Policy Decision and Enforcement 18

 6.2 RBAC/ABAC Concepts and Deny-by-Default 18

 6.3 Authorization-Decision Matrix (directive item 48) 18

 6.R RACI / Control Ownership 18

 Human Review Focus 19

Delegation, Impersonation & Effective Principal..... 20

 7.0 Salient Things to Note 20

 7.1 Delegation Context and Effective Principal 20

 7.2 Anti-Impersonation and Provenance 20

 7.3 Delegation Matrix (directive item 48)..... 20

 7.R RACI / Control Ownership 20

 Human Review Focus 21

Privileged Access Management..... 22

 8.0 Salient Things to Note 22

 8.1 Admin/Content Separation 22

 8.2 Scoped Elevation and Session Controls..... 22

 8.3 Privileged/Break-Glass Matrix, Part 1 — Ordinary Privileged Elevation (directive item 48) 22

 8.R RACI / Control Ownership 22

 Human Review Focus 23

Break-Glass & Emergency Access 24

 9.0 Salient Things to Note 24

 9.1 Bounded Emergency Elevation 24

 9.2 Notification, Audit and Post-Event Review 24

 9.3 Privileged/Break-Glass Matrix, Part 2 — Emergency Access (directive item 48) 24

 9.R RACI / Control Ownership 24

 Human Review Focus 25

Session, Token & Credential Security 26

 10.0 Salient Things to Note 26

 10.1 Scope, Audience and Expiry 26

 10.2 Credential Isolation from Agent Context 26

 10.3 Revocation, Binding and Replay Protection 26

 10.R RACI / Control Ownership 26

Human Review Focus 26

Secrets Management & Key Governance Interface 27

 11.0 Salient Things to Note 27

 11.1 Secrets Lifecycle and Isolation 27

 11.2 Key Governance Interface and SoD 27

 11.R RACI / Control Ownership 27

Human Review Focus 27

Cryptography & Data Protection 28

 12.0 Salient Things to Note 28

 12.1 Encryption Is Not Authorization 28

 12.2 Field Protection, Tokenization and Key Separation 28

 12.R RACI / Control Ownership 28

Human Review Focus 28

Network Zero Trust & Service-to-Service Security 29

 13.0 Salient Things to Note 29

 13.1 Reachability Is Not Authorization 29

 13.2 Segmentation, Service Identity and Agent Egress 29

 13.R RACI / Control Ownership 29

Human Review Focus 29

Agent Runtime & Sandbox Security 30

 14.0 Salient Things to Note 30

 14.1 Sandbox Isolation and Escape Prevention 30

 14.2 Synthesis Does Not Expand Permission 30

 14.R RACI / Control Ownership 30

Human Review Focus 30

Model & Provider Security 31

 15.0 Salient Things to Note 31

 15.1 Eligibility Is Not Disclosure Authority 31

 15.2 Provider Posture and Minimization 31

 15.R RACI / Control Ownership 31

Human Review Focus 31

Tool, Connector & External-System Security 32

 16.0 Salient Things to Note 32

 16.1 Eligibility Does Not Authorize Invocation 32

 16.2 Connector Identity, Egress and Reconciliation 32

 16.R RACI / Control Ownership 32

Human Review Focus 32

Context, Memory & Retrieval Security 33

 17.0 Salient Things to Note 33

 17.1 Propagation Is Not Authorization 33

 17.2 Semantic Retrieval and Isolation 33

17.3 Cached Context Reconciliation 33

17.R RACI / Control Ownership 33

Human Review Focus 33

Data Classification, DLP & Disclosure Controls 34

18.0 Salient Things to Note 34

18.1 Classification Travels With Data 34

18.2 VPF PASS Does Not Authorize Disclosure 34

18.3 Data-Flow Security Matrix (directive item 48)..... 34

18.R RACI / Control Ownership 34

Human Review Focus 35

Protected Identity & Privacy Security 36

19.0 Salient Things to Note 36

19.1 Minimum Necessary, Not Merely Retrievable 36

19.2 Inference Sensitivity 36

19.R RACI / Control Ownership 36

Human Review Focus 36

Security Logging, Audit & Provenance Interface..... 37

20.0 Salient Things to Note 37

20.1 Telemetry ≠ Audit ≠ Provenance 37

20.2 Logging Is Not Authority to Disclose..... 37

20.R RACI / Control Ownership 37

Human Review Focus 37

Detection, Monitoring & Security Analytics 38

21.0 Salient Things to Note 38

21.1 Detection Classes 38

21.2 Analytics Are Not Institutional Findings 38

21.R RACI / Control Ownership 38

Human Review Focus 38

Security Incident Response & Containment 39

22.0 Salient Things to Note 39

22.1 Incident Lifecycle 39

22.2 Evidence Preservation and Recovery Handoff..... 39

22.R RACI / Control Ownership 39

Human Review Focus 39

Supply-Chain, Dependency & Artifact Security..... 40

23.0 Salient Things to Note 40

23.1 Provenance and Integrity, Not Automatic Authorization 40

23.2 Generated-Code Security Gate 40

23.R RACI / Control Ownership 40

Human Review Focus 40

Vulnerability, Patch & Security Exception Management 41

24.0 Salient Things to Note 41

24.1 Remediation Lifecycle 41

24.2 Security Exceptions Are Scoped and Expiring 41

24.R RACI / Control Ownership 41

Human Review Focus 41

Resilience, Recovery & Security Reconciliation 42

25.0 Salient Things to Note 42

25.1 Recovery Is Not Reauthorization 42

25.2 Compromised Backups and Secure Failover 42

25.R RACI / Control Ownership 42

Human Review Focus 42

Security Testing, Assurance & Adversarial Validation 43

26.0 Salient Things to Note 43

26.1 Test Classes..... 43

26.2 Test-Status Integrity..... 44

26.R RACI / Control Ownership 44

Human Review Focus 44

Human Review Register & Open Security Decisions 45

27.1 Purpose 45

27.2 Summary 45

27.3 Complete Register..... 45

27.4 Mechanical Verification 50

27.5 Upstream Deduplication (Directive Item 51)..... 50

27.6 Blocking Scope Discipline 50

Human Review Focus 50

Traceability, Acceptance & Downstream Handover 51

28.0 Salient Things to Note 51

28.1 Traceability Matrix 51

28.2 Traceability Mechanical Verification 52

28.3 Skeleton-to-Full Fidelity Verification 52

28.4 Security-Control-Ownership Matrix 52

28.5 Acceptance Criteria and the Unresolved-Item Gate 53

28.6 Downstream Handover Register 54

28.7 Readiness and Final Disposition..... 54

Human Review Focus 54

Mandate, Authority Chain & Security Boundary

Establish NCIE-009 ownership of detailed Security, IAM and Zero-Trust architecture under approved NCIE-008 governance. Security enforces approved institutional authority; it does not create institutional decision rights.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-002 security architecture; NCIE-004 engineering; NCIE-006/007 current authorization; NCIE-008 governance.

1.0 Salient Things to Note

NCIE-009 enforces approved authority decisions; it does not invent institutional decision rights. Human-Primary governance (NCIE-008 Ch.2) and current authorization (NCIE-006/007) remain controlling over every control in this document — a security control that passes does not become an institutional approval.

1.1 Mandate and Scope

NCIE-009 defines the identity, access, cryptographic, network, runtime, data, logging, detection, incident, supply-chain, resilience and testing controls that enforce the approved NCIE-001–008 authority chain. It does not assign RACI, approval ownership or risk-acceptance authority — those remain NCIE-008's.

1.2 Security Boundary — What NCIE-009 Does Not Own

NCIE-009 does not own product requirements, system architecture, canonical data, engineering baseline, ARGUS behavior, Memory/Context architecture, orchestration or institutional governance. It owns the security enforcement layer beneath and across all of them.

Table 1. NCIE-009 security boundary.

Concern	Owned By
Product requirements/scope	NCIE-001
System architecture	NCIE-002
Canonical data model	NCIE-003
Engineering baseline	NCIE-004
ARGUS behavioral authority	NCIE-005
Memory & Context architecture	NCIE-006
AI/Agent/Model orchestration	NCIE-007
Institutional governance, RACI, risk acceptance	NCIE-008
Detailed Security, IAM, Zero-Trust architecture	NCIE-009 (this document)
API design, UX, physical storage, operations, detailed testing	NCIE-011/012/014/015/016 (downstream)

1.3 Interfaces to NCIE-008 Decision Rights

Every consequential security control in this document (approval, suspension, exception, emergency access) is expressed as enforcement of an NCIE-008 decision-right class (NCIE-008 Ch.4); where NCIE-008 has not yet assigned the accountable holder, this document states the control and defers the assignment to the existing NCIE-008 Human Review Register rather than inventing an authority.

1.R RACI / Control Ownership

Table 2. Chapter 1 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
-------------------	------------------------	------------------------	-----------	----------

Adopt/confirm NCIE-009 security architecture	Accountable Authority Class (NCIE-008, to be assigned)	Security Architecture Owner (to be assigned)	NCIE-008 chapter owners	All institutional role holders
--	---	--	----------------------------	-----------------------------------

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-1-1: Confirm the acceptance authority for NCIE-009 as a whole and the security-architecture sign-off authority for each of its 28 chapters.

Traceability: NCIE-002 Ch.4/Ch.24; NCIE-004; NCIE-006/007 current authorization; NCIE-008 Ch.1/Ch.4.

Security Principles, Threat Model & Trust Assumptions

Establish security doctrine — Zero Trust, least privilege, assume breach, defense in depth, explicit verification — and the threat categories, assets and trust boundaries this document defends, without fabricating institutional risk appetite.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-002 Zero Trust; NCIE-004 security boundaries; NCIE-007 runtime isolation.

2.0 Salient Things to Note

No network, component or identity is trusted merely by placement. Users, workloads, Agents, models, Tools, data paths and supply chain are each independently governed trust subjects — a control that verifies one does not thereby verify another.

2.1 Security Doctrine

Zero Trust: no network, component or identity is trusted merely by placement. Least privilege: every principal holds the minimum access its current, verified task requires. Assume breach: controls are designed to limit blast radius, not only to prevent entry. Defense in depth: no single control is relied upon exclusively. Explicit verification: every access decision re-evaluates current identity, authorization and context rather than trusting a prior grant.

2.2 Trust Subjects and Threat Actors

Users, workloads, Agents, models, Tools, data paths and the software supply chain are each independently governed trust subjects. Threat actors considered include external attackers, compromised credentials, malicious or compromised insiders, compromised third-party providers, and adversarial or unintentionally harmful Agent/model behavior (including prompt injection). Institutional risk appetite (how much residual risk is acceptable) is not fabricated here — it is a Human Review decision.

2.3 Assets and Trust Boundaries

Protected assets include identities and credentials, institutional data (classified per NCIE-003), Agent/model/Tool execution integrity, and the governance decision records NCIE-008 defines. Trust boundaries separate Human Principals from Agent/service identities, tenant/investigation contexts from one another, and this system from external networks and providers.

2.R RACI / Control Ownership

Table 3. Threat-Control Traceability Matrix (directive item 49).

Threat / Abuse Case	Preventive Control	Detective Control	Responsive Control	Recovery Control
Credential theft / account takeover	MFA, phishing-resistant auth (Ch.5)	Anomalous authn/session detection (Ch.21)	Session/credential revocation (Ch.10, Ch.22)	Re-enrollment, secure recovery (Ch.4, Ch.25)
Privilege escalation	Least-privilege, SoD-bound elevation (Ch.8)	Privileged-access anomaly detection (Ch.21)	Incident containment, revocation (Ch.22)	Post-event review, access reconciliation (Ch.25)
Agent sandbox escape	Sandbox isolation, resource ceilings (Ch.14)	Runtime/behavioral anomaly detection (Ch.21)	Agent suspension, containment (Ch.22)	Sandbox rebuild, integrity reconciliation (Ch.25)
Prompt injection / instruction hijack	Trust-hierarchy containment (Ch.17,	Prompt-injection indicator monitoring	Session/Agent containment (Ch.22)	Context reconciliation

	NCIE-007 Ch.25)	(Ch.21)		(Ch.17, Ch.25)
Data exfiltration / DLP bypass	Classification-aware DLP (Ch.18)	Exfiltration detection (Ch.21)	Disclosure containment, credential revocation (Ch.22)	Impact assessment, disclosure review (Ch.18, Ch.25)
Supply-chain / dependency compromise	Provenance/integrity verification (Ch.23)	Vulnerability/anomaly scanning (Ch.24)	Quarantine, containment (Ch.22, Ch.23)	Rebuild from verified artifacts (Ch.25)
Compromised backup / stale-state reactivation	Backup integrity controls (Ch.25)	Restore-trust verification (Ch.25)	Restore halt, compromised-backup handling (Ch.25)	Current-state reconciliation before reactivation (Ch.25)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-2-1: Approve institutional risk appetite and confirm any unresolved threat assumptions not settled by the approved upstream chain.

Traceability: NCIE-002 Zero Trust doctrine; NCIE-004 security boundaries; NCIE-007 runtime isolation.

Identity Taxonomy & Principal Model

Define the security principal classes this document secures and their non-equivalence, without inventing named offices (that remains NCIE-008 Chapter 3's role taxonomy).

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-003 identities; NCIE-006/007 runtime identity; NCIE-008 role boundary.

3.0 Salient Things to Note

Human Principal, Agent Runtime, Service/Workflow, Validator and administrative identities remain distinct at every layer of this specification. Technical identity is never a governance role — Chapter 3's taxonomy operationalizes this by fixing one authoritative source per principal class (Table 4) so no chapter below may treat one class's credential as proof of another's identity.

3.1 Principal Classes

Seven principal classes are distinguished: Human identity, workload identity, Agent identity, service identity, session/device identity, privileged identity, and validator identity. Each carries its own authoritative source, lifecycle and credential class; none substitutes for another.

Table 4. Security principal taxonomy.

Principal Class	Authoritative Source	Never Substitutes For
Human identity	Institutional identity source (Ch.4 proofing)	Any technical identity
Workload identity	Deployment/orchestration platform	Human or Agent identity
Agent identity	Agent Factory/Registry (NCIE-007)	Human identity (invariant: AGENT IDENTITY ≠ HUMAN IDENTITY)
Service identity	Service registration	Human identity (invariant: SERVICE IDENTITY ≠ HUMAN IDENTITY)
Session/device identity	Authentication session issuance (Ch.5, Ch.10)	Underlying Human/Agent identity
Privileged identity	Privileged access management (Ch.8)	Ordinary identity of same holder
Validator identity	VPF validator registration (NCIE-007)	Human or institutional approval authority

3.2 Technical Identity vs Governance Role

TECHNICAL IDENTITY ≠ INSTITUTIONAL GOVERNANCE ROLE. Authenticating as any of the above principal classes never itself confers an NCIE-008 governance role (Accountable Authority, Approver, and so on); a governance role is held by an identified accountable human or institutional function per NCIE-008 §3.2, independent of which technical identity is used to act.

3.R RACI / Control Ownership

Table 5. Chapter 3 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Define/modify the identity taxonomy	Accountable Authority Class (to be assigned)	Security Architecture Owner (to be assigned)	NCIE-008 Ch.3 role-taxonomy owner	All chapter owners

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-3-1: Confirm the authoritative identity source for each principal class and any institution-specific identity classes not covered above.

Traceability: NCIE-003 identities; NCIE-006/007 runtime identity; NCIE-008 Ch.3 role boundary.

Identity Proofing, Enrollment & Lifecycle

Define how Human identities are established, changed, suspended, terminated, reactivated and recovered, and the authoritative-source requirements for each event.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-005 protected identity/voice; NCIE-008 governance.

4.0 Salient Things to Note

Proofing is never inferred from conversation or voice presence. Every lifecycle event — suspension and termination especially — requires traceability and immediate revocation propagation to sessions, tokens and cached authorization state; a suspended identity that can still act through a stale session or cache is a control failure, not an acceptable delay.

4.1 Lifecycle Events

Proofing, enrollment, activation, update, suspension, termination, reactivation, recovery and duplicate-identity handling are each distinct, traceable events. Every event propagates revocation and re-evaluation to dependent sessions, tokens and cached authorization state (Ch.10, Ch.17) rather than taking effect only at next login.

4.2 Proofing Is Not Inferred From Conversation

Voice presence, conversational familiarity or ARGUS session history is never proofing evidence (NCIE-005 protected-identity boundary). Proofing strength is bound to an authoritative institutional identity source; where no such source is fixed upstream, this document defers the required proofing strength to Human Review rather than inventing one.

4.R RACI / Control Ownership

Table 6. Chapter 4 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve proofing strength/enrollment authority	Accountable Authority Class (to be assigned)	Identity Lifecycle Operator (to be assigned)	NCIE-005 protected-identity owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-4-1: Approve the required proofing strength per identity class and the institutional enrollment authority.

Traceability: NCIE-005 protected identity/voice boundary; NCIE-008 governance.

Authentication Architecture

Define the authentication assurance architecture: what authentication establishes, how session authentication, step-up, reauthentication and recovery work, without inventing specific factors or thresholds.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-002/004 security; NCIE-008 decision rights.

5.0 Salient Things to Note

Authentication establishes identity assurance, not action authorization — a passed authentication check is never itself cited as proof that an action was authorized. Higher-risk operations may require stronger or more recent authentication; Table 7 fixes the assurance-context taxonomy without inventing the specific factor sets or thresholds directive item 9 prohibits fabricating.

5.1 Assurance, Not Authorization

Authentication establishes identity assurance — confidence that a session is acted on by the claimed principal — not action authorization (AUTHENTICATED IDENTITY ≠ AUTHORIZED ACTION). Authorization is evaluated separately and currently by Chapter 6 for every consequential action.

5.2 Step-Up, Reauthentication and Recovery

Higher-risk operations may require stronger or more recent authentication (step-up) than the session's original assurance level. Reauthentication and account recovery are themselves governed lifecycle events (Ch.4) and must not silently restore a higher privilege than the recovering principal currently holds.

5.3 Identity-Assurance Matrix (directive item 48)

The assurance-context taxonomy below fixes which situations require elevated or step-up assurance, without inventing the specific factor sets or numeric thresholds directive item 9 prohibits fabricating.

Table 7. Identity-Assurance Matrix.

Assurance Context	Minimum Assurance Concept	Step-Up Trigger Concept	Human Review Status
Standard session use	Baseline authentication (factor set not fixed here)	N/A	Holder — Human Review
Privileged access (Ch.8)	Elevated assurance above baseline	Elevation request	Holder — Human Review
Break-glass access (Ch.9)	Elevated assurance plus governed trigger	Emergency trigger declared	Holder — Human Review
High-risk consequential action (Ch.16, NCIE-008 Ch.14)	Elevated or recent assurance	Action classified high-risk	Holder — Human Review
Post-recovery session (Ch.4, Ch.25)	Re-proofed assurance, not inherited from pre-incident session	Recovery event	Holder — Human Review

5.R RACI / Control Ownership

Table 8. Chapter 5 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve assurance	Accountable	Authentication	Reviewer	Assurance/Audit

levels/step-up triggers	Authority Class (to be assigned)	Architecture Owner (to be assigned)	(NCIE-008)
-------------------------	----------------------------------	-------------------------------------	------------

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-5-1: Approve assurance levels and step-up triggers per Table 7; no specific factor set or numeric threshold is adopted by default absent a sourced institutional decision.

Traceability: NCIE-002/004 security architecture; NCIE-008 decision rights.

Authorization Architecture & Policy Decision Model

Define current-authorization evaluation across object, field, action and purpose boundaries, with deny-by-default as the controlling default.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-002 four-layer authorization; NCIE-006 Ch.25; NCIE-007 Ch.14; NCIE-008 authority classes.

6.0 Salient Things to Note

Authorization is current and role/object/field/action/purpose-aware where NCIE-003 classification applies; remembered authorization is never current authority. Table 9 fixes deny-by-default as the control for all four layers, operationalizing the skeletal note into an enforceable default rather than an aspiration.

6.1 Policy Decision and Enforcement

A policy decision point evaluates current authorization at the moment of the request; a policy enforcement point applies the decision at the point of access. REMEMBERED AUTHORIZATION ≠ CURRENT AUTHORIZATION: a decision cached from an earlier request is never substituted for re-evaluation when the request, principal, or protected object's state may have changed.

6.2 RBAC/ABAC Concepts and Deny-by-Default

Role- and attribute-based concepts inform authorization at the object, field, action and purpose level where NCIE-003 classification requires it. Absent an explicit, current, affirmative grant, access is denied — deny-by-default is not an optional posture.

6.3 Authorization-Decision Matrix (directive item 48)

The four authorization layers below share the same deny-by-default enforcement posture.

Table 9. Authorization-Decision Matrix.

Authorization Layer	Decision Basis	Enforcement Point	Default	Human Review Status
Object-level	Current role/attribute grant	Policy enforcement point at access	Deny	Holder — Human Review
Field-level	NCIE-003 classification + current grant	Policy enforcement point at field read	Deny	Holder — Human Review
Action-level	Current role/attribute grant for the specific action	Policy enforcement point at action invocation	Deny	Holder — Human Review
Purpose-level	Declared purpose consistent with classification/consent	Policy enforcement point at request time	Deny	Holder — Human Review

6.R RACI / Control Ownership

Table 10. Chapter 6 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve authorization policy model/role-attribute	Accountable Authority Class (to be assigned)	Authorization Architecture Owner (to be assigned)	Reviewer	Assurance/Audit (NCIE-008)

mappings

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-6-1: Approve the authorization policy model in Table 9 and confirm unresolved role/attribute mappings.

Traceability: NCIE-002 four-layer authorization; NCIE-006 Ch.25; NCIE-007 Ch.14; NCIE-008 authority classes.

Delegation, Impersonation & Effective Principal

Secure delegated work — Agent-on-behalf-of-Human, Human-to-Human, service-to-service — without copying reusable human credentials into runtime Context or expanding authority through delegation.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-006/007 delegated authorization; NCIE-008 delegation governance.

7.0 Salient Things to Note

DELEGATED TASK ≠ HUMAN CREDENTIAL DELEGATION. Workload identity and the effective Human Principal remain separately attributable at every step — Table 11 operationalizes this by binding every delegation class to an explicit scope, expiry and revocation trigger rather than leaving delegation open-ended.

7.1 Delegation Context and Effective Principal

DELEGATED TASK ≠ HUMAN CREDENTIAL DELEGATION. A delegated task carries a scoped delegation context (effective principal, scope, expiry) rather than a copy of the delegating Human's reusable credential. The workload/Agent identity performing the task and the effective Human Principal it acts for remain separately attributable at every step (DELEGATION ≠ AUTHORITY EXPANSION, inherited from NCIE-008).

7.2 Anti-Impersonation and Provenance

A delegated actor must not be able to represent itself as the delegating principal for a purpose outside the delegation's stated scope. Every delegated action's provenance record preserves both the acting identity and the effective principal.

7.3 Delegation Matrix (directive item 48)

Every delegation class below is bound to an explicit scope, expiry and revocation trigger rather than left open-ended.

Table 11. Delegation Matrix.

Delegation Class	Scope Binding	Expiry	Revocation	Human Review Status
Agent acting for Human Principal	Task Contract scope (NCIE-007)	Run-bound	Immediate on Human authorization change	Holder — Human Review
Agent-to-Agent delegation	Subtask scope (NCIE-007 Ch.13)	Subtask-bound	Immediate on parent Run revocation	Holder — Human Review
Service-to-service delegation	Service registration scope	Session-bound	Immediate on service credential revocation	Holder — Human Review
Human-to-Human delegation (e.g. deputisation)	NCIE-008 Ch.5 acting/deputy scope	Time-boxed per NCIE-008 §5.2	Per NCIE-008 deputisation record	Holder — Human Review

7.R RACI / Control Ownership

Table 12. Chapter 7 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve	Accountable	Delegation Security	Reviewer	Assurance/Audit

permitted/prohibited delegation classes	Authority Class (to be assigned)	Owner (to be assigned)	(NCIE-008)
--	-------------------------------------	---------------------------	------------

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-7-1: Confirm the permitted and prohibited delegation classes in Table 11.

Traceability: NCIE-006/007 delegated authorization; NCIE-008 Ch.5 RACI/delegation governance.

Privileged Access Management

Define privileged administrative access as scoped, attributable and governed, separated from substantive content authority.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-006 SYSTEM ADMINISTRATION ≠ CONTENT AUTHORITY; NCIE-008 Ch.20.

8.0 Salient Things to Note

Administrative privilege does not automatically authorize substantive content access. Privileged access is scoped, attributable and governed — Table 13 fixes three privilege classes each bound to a named scope and an NCIE-008 approval interface, so 'has admin rights' can never be read as 'may read institutional content.'

8.1 Admin/Content Separation

SECURITY ADMINISTRATION ≠ SUBSTANTIVE CONTENT AUTHORITY. Administrative privilege (managing identities, configuration, infrastructure) does not automatically authorize access to substantive institutional content; the two are separately granted and separately audited.

8.2 Scoped Elevation and Session Controls

Privileged access is elevated for a bounded scope and duration (a just-in-time concept), requires an approval interface consistent with NCIE-008 Ch.4/Ch.10 decision rights, and is subject to session controls (Ch.10) and privileged-specific audit (Ch.20) distinct from ordinary session logging.

8.3 Privileged/Break-Glass Matrix, Part 1 — Ordinary Privileged Elevation (directive item 48)

Ordinary (non-emergency) privileged elevation is fixed to three classes, each bound to a named scope and an NCIE-008 approval interface.

Table 13. Privileged/Break-Glass Matrix, Part 1.

Privilege Class	Elevation Trigger	Scope	Approval Interface	Human Review Status
Infrastructure/configuration admin	Elevation request	Named system/config scope	NCIE-008 Ch.4 Authorization decision-right	Holder — Human Review
Identity/IAM admin	Elevation request	Named identity-management scope	NCIE-008 Ch.4 Authorization decision-right	Holder — Human Review
Data/content admin (distinct from infra admin)	Elevation request + content-specific justification	Named content scope	NCIE-008 Ch.4 Authorization + Ch.10 Acceptance	Holder — Human Review

8.R RACI / Control Ownership

Table 14. Chapter 8 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve privileged-access classes/authority	Accountable Authority Class (to be assigned)	Privileged Access Owner (to be assigned)	Reviewer	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-8-1: Confirm privileged-access approval authority and classes in Table 13.

Traceability: NCIE-006 admin/content boundary; NCIE-008 Ch.20 security governance interface.

Break-Glass & Emergency Access

Define emergency access mechanics — trigger, elevation, scope, expiry, notification, audit, revocation and post-event review — under NCIE-008 governed emergency authority.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-008 Ch.20/Ch.22; NCIE-006 break-glass boundary.

9.0 Salient Things to Note

Emergency access is scoped, temporary, auditable and post-reviewed — never a silent path to standing privilege. Table 15 binds every break-glass class to an auto-expiring scope and an independent post-event reviewer, so BREAK-GLASS ≠ PERMANENT PRIVILEGE is enforced structurally, not just stated.

9.1 Bounded Emergency Elevation

BREAK-GLASS ≠ PERMANENT PRIVILEGE. A break-glass trigger grants a scoped, time-boxed elevation under the NCIE-008 Emergency Authority role class (NCIE-008 Ch.22), never a standing privilege increase.

9.2 Notification, Audit and Post-Event Review

Every break-glass action triggers mandatory notification and produces an audit record distinct from ordinary privileged-access logging (Ch.20). Reinstatement or permanent disposition follows only from an independent post-event review — never from the acting Emergency Authority alone (NCIE-008 Ch.6/Ch.22 SoD).

9.3 Privileged/Break-Glass Matrix, Part 2 — Emergency Access (directive item 48)

Every emergency class below is bound to an auto-expiring scope and an independent post-event reviewer, so break-glass cannot become a silent path to standing privilege.

Table 15. Privileged/Break-Glass Matrix, Part 2.

Emergency Class	Trigger	Scope	Expiry	Post-Event Review	Human Review Status
Identity/access emergency suspension	Declared security emergency	Named identity/session scope	Time-boxed, auto-expiring	Independent NCIE-008 Ch.22 review	Holder — Human Review
Agent/model/Tool emergency suspension	Declared security emergency	Named Agent/model/Tool scope	Time-boxed, auto-expiring	Independent NCIE-008 Ch.22 review	Holder — Human Review
Infrastructure break-glass admin	Declared operational emergency	Named system scope	Time-boxed, auto-expiring	Independent NCIE-008 Ch.22 review	Holder — Human Review

9.R RACI / Control Ownership

Table 16. Chapter 9 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Trigger/reinstate break-glass access	Emergency Authority (NCIE-008, to be assigned)	Break-Glass Operator (to be assigned)	Domain Accountable Authority (post-event)	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-9-1: Confirm break-glass authority, eligible emergency classes and post-event review rules in Table 15.

Traceability: NCIE-008 Ch.20/Ch.22 emergency authority; NCIE-006 break-glass boundary.

Session, Token & Credential Security

Define the lifecycle and protection of sessions, tokens and credentials: scope, audience, expiry, refresh, revocation, binding, storage and replay protection.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 IAM/secrets; NCIE-006/007 current authorization.

10.0 Salient Things to Note

Human credentials are never copied into Agent Context, and session continuity does not imply indefinite authorization. This chapter treats revocation as an immediate, cross-system event — a token still honored after its issuing credential was revoked is a control failure, not a caching nuance.

10.1 Scope, Audience and Expiry

Every token/session carries an explicit scope and audience; it is not valid beyond the resource or purpose it was issued for. Session continuity does not imply indefinite authorization — expiry and refresh are governed events, not implementation details left unspecified.

10.2 Credential Isolation from Agent Context

Human credentials are never copied into Agent Context (AGENT CONTEXT ≠ AGENT AUTHORITY, inherited from NCIE-008 Ch.17; CONTEXT PROPAGATION ≠ AUTHORIZATION PROPAGATION). An Agent acts under its own delegated context (Ch.7), never under a reusable Human credential.

10.3 Revocation, Binding and Replay Protection

Revocation of a session, token or credential takes effect immediately across every dependent system, not only at next validation. Session binding and replay protection prevent a captured token from being reused outside its original context.

10.R RACI / Control Ownership

Table 17. Chapter 10 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve session assurance/expiry and credential classes	Accountable Authority Class (to be assigned)	Session/Credential Security Owner (to be assigned)	Reviewer	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-10-1: Approve session assurance/expiry policy and credential classes; no specific duration is adopted by default absent a sourced institutional decision.

Traceability: NCIE-004 IAM/secrets architecture; NCIE-006/007 current authorization.

Secrets Management & Key Governance Interface

Define secrets and cryptographic-key security — lifecycle, issuance, rotation, access, storage, workload delivery and SoD — without choosing specific products.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 secrets architecture; NCIE-008 policy/SoD.

11.0 Salient Things to Note

Secrets must not appear in prompts, logs, Agent Context or source code — this is treated as an absolute prohibition, not a best-effort guideline, and any occurrence is routed to Chapter 22 incident response. Key custody is kept distinct from ordinary application identity so that using a key is never conflated with owning it.

11.1 Secrets Lifecycle and Isolation

Secrets must never appear in prompts, logs, Agent Context or source code. Issuance, rotation, access and storage are each governed events with an attributable actor; a secret's presence in any of the prohibited surfaces is a security incident (Ch.22), not a logging nuance.

11.2 Key Governance Interface and SoD

Key custody is distinct from ordinary application identity: a workload that uses a key is not thereby the key's custodian. Key-hierarchy concepts (root, intermediate, data-encryption keys) and rotation are addressed conceptually; the specific product/HSM/KMS choice is not fixed here (directive item 8). Custodial and audit functions are segregated per NCIE-008 Ch.6 SoD.

11.R RACI / Control Ownership

Table 18. Chapter 11 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve secrets/key custodial authority and exceptions	Accountable Authority Class (to be assigned)	Secrets/Key Custodian (to be assigned)	Assurance/Audit (NCIE-008, SoD-independent per Ch.6)	Domain owners

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-11-1: Confirm secrets/key custodial authority and the exception policy for secret handling.

Traceability: NCIE-004 secrets architecture; NCIE-008 Ch.6 SoD, Ch.7 policy ownership.

Cryptography & Data Protection

Define protection expectations for data at rest, in transit and in sensitive fields, conceptually, without inventing specific algorithms.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-003 sensitive fields; NCIE-004 engineering; NCIE-006 protected identity.

12.0 Salient Things to Note

ENCRYPTION ≠ AUTHORIZATION — an encrypted store or channel is never cited as itself proving an access was authorized. No specific cryptographic algorithm, key length or product is fixed here; this chapter states the protection classes and defers algorithm selection to engineering/institutional decision where not already fixed upstream.

12.1 Encryption Is Not Authorization

ENCRYPTION ≠ AUTHORIZATION. Cryptographic protection of data in transit, at rest, or in specific fields does not replace IAM, classification, purpose or disclosure controls — an encrypted channel or store still requires a current, authorized principal to access its contents.

12.2 Field Protection, Tokenization and Key Separation

NCIE-003-classified sensitive fields receive field-level protection (tokenization or masking) in addition to transport/at-rest protection. Keys protecting different sensitivity tiers are separated so that compromise of one does not compromise another; crypto agility (the ability to change algorithms without redesigning the system) is a design property, not a specific algorithm choice made here.

12.R RACI / Control Ownership

Table 19. Chapter 12 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve cryptographic policy where not fixed upstream	Accountable Authority Class (to be assigned)	Cryptography/Data Protection Owner (to be assigned)	NCIE-003 classification owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Non-Blocking) HR9-12-1: Approve cryptographic policy (algorithm families, key-separation tiers) where not already fixed by an approved upstream source; does not block use of the conceptual protections already stated above.

Traceability: NCIE-003 sensitive-field classification; NCIE-004 engineering; NCIE-006 protected identity.

Network Zero Trust & Service-to-Service Security

Define network and service-to-service security under explicit verification: segmentation, service identity, authenticated transport, ingress/egress and deny-by-default network policy.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 network controls; NCIE-007 Agent egress ceilings.

13.0 Salient Things to Note

Agents require bounded egress and services require identity/policy controls regardless of network placement. Deny-by-default network policy is the fixed default here; any exception is scoped, attributable and traced to an NCIE-008 exception decision right (NCIE-008 Ch.21), not a silent firewall rule.

13.1 Reachability Is Not Authorization

NETWORK REACHABILITY ≠ APPLICATION AUTHORIZATION. A service being network-reachable never substitutes for the current-authorization check Chapter 6 requires at the application layer.

13.2 Segmentation, Service Identity and Agent Egress

Network segmentation, mutual-authenticated transport concepts, and private connectivity bound lateral movement. Ingress and egress are deny-by-default with explicit, scoped exceptions. Agent Runtime egress is additionally bounded by the ceilings NCIE-007 Ch.14/34 define — an Agent does not gain broader network reach than its sandbox and Task Contract permit.

13.R RACI / Control Ownership

Table 20. Chapter 13 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Confirm trust zones, egress classes and exceptions	Accountable Authority Class (to be assigned)	Network Security Owner (to be assigned)	NCIE-007 Agent Runtime owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-13-1: Confirm network trust zones, Agent/external egress classes and exception-granting authority.

Traceability: NCIE-004 network controls; NCIE-007 Agent egress ceilings.

Agent Runtime & Sandbox Security

Define sandbox security controls for Registered and Ephemeral Agent execution: workload identity, resource ceilings, and filesystem/process/network/Tool/Context/persistence boundaries.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 Agent Factory/runtime; NCIE-006 Context; NCIE-007 synthesis.

14.0 Salient Things to Note

Agent Runtime Identity is never Human Identity, and synthesis cannot expand permission. Isolation bounds filesystem, process, network, Tools, Context and persistence for every Run — this chapter requires cleanup and escape-prevention verification as a release gate, not a monitoring afterthought.

14.1 Sandbox Isolation and Escape Prevention

Each Agent Run executes under its own workload identity within a sandbox bounding filesystem, process, network, Tool access, Context and persistence. Escape from this boundary into another Run's sandbox, the host, or another Agent's Context is a security incident (Ch.22), not a logging event.

14.2 Synthesis Does Not Expand Permission

Dynamic Agent Synthesis (NCIE-007 Ch.11–12) creates an Agent whose runtime identity is bound by the same sandbox ceilings as any other Agent of its class; synthesis itself confers no additional permission (AGENT IDENTITY ≠ HUMAN IDENTITY; PROMOTION RECOMMENDATION ≠ REGISTRATION APPROVAL, inherited from NCIE-008). Generated code within a synthesized Agent is additionally gated by Chapter 23's supply-chain/generated-code security review before execution.

14.R RACI / Control Ownership

Table 21. Chapter 14 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Confirm Agent Factory security ceilings/generated-code gate	Accountable Authority Class (to be assigned)	Agent Runtime Security Owner (to be assigned)	NCIE-007 Agent Factory owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [SECURITY/SOVEREIGNTY CONFIRMATION REQUIRED] (Blocking) HR9-14-1: Confirm Agent Factory security ceilings and the generated-code security-review requirement before any generated-code Agent path is activated.

Traceability: NCIE-004 Agent Factory/runtime; NCIE-006 Context boundaries; NCIE-007 synthesis doctrine.

Model & Provider Security

Define security controls for model and provider use: provider security posture, model eligibility, data handling, retention, residency, minimization and provider-incident response.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-007 Model Gateway; NCIE-006 Context; NCIE-008 model governance.

15.0 Salient Things to Note

Provider and model use must satisfy classification, residency, retention, purpose and security constraints together — satisfying one does not waive the others. This chapter treats minimization as a control to verify (only necessary data sent) rather than a general principle to invoke after the fact.

15.1 Eligibility Is Not Disclosure Authority

MODEL ELIGIBILITY ≠ DATA DISCLOSURE AUTHORITY. A model being technically and institutionally eligible for a use case (NCIE-007 Ch.7, NCIE-008 Ch.13) does not itself authorize disclosing a specific classified field to it — classification, purpose and current authorization (Ch.6, Ch.18) govern disclosure separately.

15.2 Provider Posture and Minimization

Provider/model use must satisfy classification, residency, retention and purpose constraints before data reaches it; only the minimum-necessary data for the current purpose is sent. A provider-security incident (Ch.22) triggers the same containment/notification interface as any other security incident.

15.R RACI / Control Ownership

Table 22. Chapter 15 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve provider-security acceptance criteria	Accountable Authority Class (to be assigned)	Model/Provider Security Owner (to be assigned)	NCIE-008 Ch.13 model governance owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [SECURITY/SOVEREIGNTY CONFIRMATION REQUIRED] (Blocking) HR9-15-1: Confirm provider-security acceptance criteria and any restricted data/provider combinations that require additional residency or sovereignty confirmation.

Traceability: NCIE-007 Model Gateway; NCIE-006 Context minimization; NCIE-008 Ch.13 model governance.

Tool, Connector & External-System Security

Define Tool, connector and external-action security: connector identity, scoped credentials, current actor/action/target authorization, egress, idempotency and OUTCOME UNKNOWN reconciliation.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 Tool Gateway; NCIE-007 Tools; NCIE-008 consequential actions.

16.0 Salient Things to Note

Tool eligibility does not authorize invocation. Calls require current actor/action/target authorization and an authoritative receipt — this chapter requires idempotency and OUTCOME UNKNOWN reconciliation as release gates so a retried or ambiguous external call cannot silently double-execute or be assumed successful.

16.1 Eligibility Does Not Authorize Invocation

TOOL ELIGIBILITY ≠ TOOL EXECUTION AUTHORITY. A Tool being registered and eligible for a Task Contract does not itself authorize invoking it — the specific actor, action and target must be currently authorized at invocation time (NCIE-008 Ch.14 consequential-action governance).

16.2 Connector Identity, Egress and Reconciliation

Each connector carries its own scoped credential, distinct from the invoking Agent's identity. Egress to external systems is bounded and logged. Where an external call's outcome cannot be confirmed, it is governed as OUTCOME UNKNOWN pending reconciliation via an authoritative receipt — never assumed successful (NCIE-008 Ch.14 §14.3).

16.R RACI / Control Ownership

Table 23. Chapter 16 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve high-risk Tool classes/security approval	Accountable Authority Class (to be assigned)	Tool/Connector Security Owner (to be assigned)	NCIE-008 Ch.14 consequential-action owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-16-1: Confirm high-risk Tool classes and the security approval requirements for each.

Traceability: NCIE-004 Tool Gateway; NCIE-007 Tool architecture; NCIE-008 Ch.14 consequential-action governance.

Context, Memory & Retrieval Security

Secure Context assembly, Memory/search and semantic retrieval: authorization filtering, isolation, cache/vector/index controls and Agent Context minimization.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-006 v1.2; NCIE-007 Ch.17; NCIE-008 Memory governance.

17.0 Salient Things to Note

Semantic similarity is never authority to disclose, and cached Context must reconcile current authorization before reuse. This chapter treats a stale-but-cached authorization result as a defect to detect, not a performance optimization to accept.

17.1 Propagation Is Not Authorization

CONTEXT PROPAGATION ≠ AUTHORIZATION PROPAGATION. Context carried forward into a new Run or Agent does not carry forward the authorization to act on it — every consequential use re-checks current authorization (Ch.6).

17.2 Semantic Retrieval and Isolation

Semantic similarity is never authority to disclose (SEMANTIC RETRIEVAL ≠ AUTHORITY TO DISCLOSE, inherited from NCIE-008 §0.3). Retrieval, vector-index and cache results are filtered by current authorization before assembly into Context, and User/Room/Investigation boundaries (NCIE-006) are enforced at the retrieval layer, not only at the display layer.

17.3 Cached Context Reconciliation

Cached or persisted Context is reconciled against current authorization before reuse — a cache hit does not bypass the authorization check a fresh retrieval would have required.

17.R RACI / Control Ownership

Table 24. Chapter 17 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve cross-context exception/security requirements	Accountable Authority Class (to be assigned)	Context/Retrieval Security Owner (to be assigned)	NCIE-008 Ch.17 Memory governance owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-17-1: Confirm the security-approval requirements for any cross-context exception (NCIE-008 Ch.17 §17.2).

Traceability: NCIE-006 v1.2 Memory & Context architecture; NCIE-007 Ch.17; NCIE-008 Ch.17 Memory governance.

Data Classification, DLP & Disclosure Controls

Translate NCIE-003 classification and NCIE-008 disclosure governance into security enforcement across Tool, export, model, voice and Agent data paths.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-003 classification; NCIE-005 voice/privacy; NCIE-006 Memory; NCIE-008 disclosure governance.

18.0 Salient Things to Note

Classification travels with data across every path in Table 25; generated and inferred data may be sensitive even though never directly sourced. VPF PASS is explicitly excluded here from ever being read as a disclosure authorization, closing a specific misreading directive item 8/37 warns against.

18.1 Classification Travels With Data

A field's classification is enforced wherever the data flows — Tool invocation, export, model input, voice output, or Agent Context — not only at its system of record. Generated or inferred data may itself be sensitive and is classified before further use, not assumed benign because it was derived rather than sourced.

18.2 VPF PASS Does Not Authorize Disclosure

VPF PASS ≠ SECURITY AUTHORIZATION. A Validated AI Result passing VPF is a content-quality/policy disposition (NCIE-007); it never itself authorizes disclosing classified content to a recipient, channel or export path that current authorization and DLP policy would otherwise deny.

18.3 Data-Flow Security Matrix (directive item 48)

Classification and DLP are enforced at a defined check point on every data path below, including paths (voice, Agent-to-Agent handoff) easy to overlook.

Table 25. Data-Flow Security Matrix.

Data Path	Classification Check Point	DLP Control	Human Review Status
Tool invocation (input/output)	Before Tool call assembly	Field-level masking/blocking per classification	Holder — Human Review
Export (file, report, API response)	Before export generation	Classification-aware export policy	Holder — Human Review
Model input (prompt/Context assembly)	Before Context/prompt assembly	Minimization + field masking	Holder — Human Review
Voice/spoken output (ARGUS, NCIE-005)	Before speech synthesis	Protected-identity/voice disclosure controls (NCIE-005)	Holder — Human Review
Agent-to-Agent handoff	Before Context handoff	Same classification checks as original path	Holder — Human Review

18.R RACI / Control Ownership

Table 26. Chapter 18 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve DLP policy	Accountable	DLP/Disclosure	NCIE-003	Assurance/Audit

classes/disclosure authorities/exceptions	Authority Class (to be assigned)	Security Owner (to be assigned)	classification owner, NCIE-008 disclosure- governance owner	(NCIE-008)
--	-------------------------------------	------------------------------------	--	------------

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-18-1: Confirm DLP policy classes, disclosure authorities and exceptions in Table 25.

Traceability: NCIE-003 classification; NCIE-005 voice/privacy; NCIE-006 Memory; NCIE-008 disclosure governance.

Protected Identity & Privacy Security

Define heightened controls for protected-identity and privacy-sensitive data: minimum necessary, vault/tokenization interface, masking, purpose limitation and inference sensitivity.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-003 protected fields; NCIE-005/006 privacy; NCIE-008 Ch.20.

19.0 Salient Things to Note

Protected identity is minimum-necessary and not exposed merely because retrievable; inference can create sensitive data from non-sensitive inputs. This chapter requires inferred sensitive output to be classified and audited at the same standard as directly sourced protected data.

19.1 Minimum Necessary, Not Merely Retrievable

Protected identity is exposed only on a minimum-necessary basis for the current, authorized purpose — being technically retrievable is not itself a basis for exposure.

19.2 Inference Sensitivity

Inference over non-protected fields can itself produce protected-identity-equivalent or otherwise sensitive data; such inferred output is classified and controlled as if directly sourced, and privacy access is audited (Ch.20) at the same standard as direct access.

19.R RACI / Control Ownership

Table 27. Chapter 19 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve protected-identity access classes/escalation authority	Accountable Authority Class (to be assigned)	Privacy Security Owner (to be assigned)	NCIE-003/005/006 privacy owners	Assurance/Audit (NCIE-008)

Human Review Focus

- [SECURITY/SOVEREIGNTY CONFIRMATION REQUIRED] (Blocking) HR9-19-1: Confirm protected-identity access classes and the escalation authority for privacy-sensitive requests.

Traceability: NCIE-003 protected fields; NCIE-005/006 privacy; NCIE-008 Ch.20 security/privacy governance interface.

Security Logging, Audit & Provenance Interface

Define security-event evidence while preserving the distinction between telemetry, audit and provenance.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-003 provenance; NCIE-006 audit; NCIE-007 observability; NCIE-008 assurance.

20.0 Salient Things to Note

Logging does not authorize disclosure, and telemetry, audit and provenance remain three distinct records with different retention and access rules. This chapter requires security logs to minimize secrets, raw prompts and raw protected data by construction, not by post-hoc redaction.

20.1 Telemetry ≠ Audit ≠ Provenance

Operational telemetry (NCIE-007 Ch.31), security audit evidence, and canonical provenance (NCIE-003) serve distinct purposes and retention rules; a security log is not automatically an audit record, and neither is automatically the provenance record of record.

20.2 Logging Is Not Authority to Disclose

LOGGING ≠ AUTHORITY TO DISCLOSE. The existence of a log entry recording an event never itself authorizes disclosing that entry's content; access to security logs is itself an authorization decision (Ch.6). Security logs avoid capturing secrets, raw prompts or raw protected data — captured references (event, actor, target, time) suffice for authn/authz, privileged-access, and Tool/Agent events, with tamper resistance and correlation across sources.

20.R RACI / Control Ownership

Table 28. Chapter 20 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve security-log retention/access; assurance interface	Accountable Authority Class (to be assigned)	Security Logging Owner (to be assigned)	NCIE-008 Ch.23 audit/assurance owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Non-Blocking) HR9-20-1: Confirm security-log retention and access policy and the interface to NCIE-008 Ch.23 assurance; does not block ongoing security-event capture in the interim.

Traceability: NCIE-003 provenance; NCIE-006 audit; NCIE-007 observability; NCIE-008 Ch.23 assurance architecture.

Detection, Monitoring & Security Analytics

Define detection for suspicious identity, access, Agent, Tool, network and data behavior, including prompt-injection indicators.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 observability; NCIE-007 operations; NCIE-008 assurance.

21.0 Salient Things to Note

Security analytics may trigger response but do not automatically become institutional Findings; monitoring minimizes sensitive-payload exposure in its own pipeline — a detection system that itself over-collects protected data is a control failure this chapter treats as in-scope.

21.1 Detection Classes

Detection covers identity/access anomalies, exfiltration indicators, Agent abuse, prompt-injection indicators, and network anomalies, each with a triage path into Chapter 22 incident response where warranted.

21.2 Analytics Are Not Institutional Findings

A security-analytics alert may trigger response but does not itself become an institutional Finding or Decision (MODEL/AGENT OUTPUT ≠ EVIDENCE, FINDING OR DECISION; NCIE-008 Ch.18 Finding/Decision authority governs that separately). Monitoring is designed to minimize exposure of sensitive payload content in the analytics pipeline itself.

21.R RACI / Control Ownership

Table 29. Chapter 21 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Own monitoring/escalation classes and severity governance	Accountable Authority Class (to be assigned)	Detection/Monitoring Owner (to be assigned)	NCIE-008 Ch.23 assurance owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Non-Blocking) HR9-21-1: Confirm monitoring ownership, escalation classes and severity governance; does not block the detection classes already specified in the interim.

Traceability: NCIE-004 observability; NCIE-007 operations; NCIE-008 Ch.23 assurance architecture.

Security Incident Response & Containment

Define the detection-to-containment-to-recovery incident lifecycle under governed emergency authority.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-008 emergency authority; NCIE-004 resilience; NCIE-007 lifecycle.

22.0 Salient Things to Note

Containment may suspend identities, Agents, Tools or models under governed emergency authority — never as an ad hoc security action outside NCIE-008's process. Evidence and historical state are preserved through containment, not cleaned up before they can be reviewed.

22.1 Incident Lifecycle

Detection, triage, containment, revocation, isolation, evidence preservation and notification are distinct, ordered stages. Containment may suspend identities, Agents, Tools or models under the NCIE-008 Ch.22 governed emergency-authority process — it is not a unilateral security action outside that governance.

22.2 Evidence Preservation and Recovery Handoff

Historical state and evidence are preserved through containment, not overwritten by remediation actions. Recovery handoff to Chapter 25 occurs only after containment is confirmed effective; recovery never recreates the authority state that existed before the incident (RECOVERY ≠ REAUTHORIZATION).

22.R RACI / Control Ownership

Table 30. Chapter 22 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Command/contain a security incident	Emergency Authority (NCIE-008, to be assigned)	Incident Response Owner (to be assigned)	Domain Accountable Authority	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-22-1: Confirm incident command authority, notification obligations and containment rights.

Traceability: NCIE-008 Ch.22 emergency authority; NCIE-004 resilience; NCIE-007 lifecycle.

Supply-Chain, Dependency & Artifact Security

Secure software, model, Agent Pattern, Tool, image/package and dependency supply chains through provenance and integrity verification.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 CI/CD; NCIE-007 Ch.34; NCIE-008 assurance.

23.0 Salient Things to Note

Artifact identity, version and provenance matter, and verified artifacts do not themselves create authorization. Generated code remains separately governed by this chapter's security gate — a successful synthesis Run is never read as satisfying it.

23.1 Provenance and Integrity, Not Automatic Authorization

Artifact identity, version and provenance are verified before use; a verified artifact's integrity does not itself create authorization to deploy or execute it — that remains a separate decision-right act (NCIE-008 Ch.4).

23.2 Generated-Code Security Gate

Generated code (from Dynamic Agent Synthesis or any other source) passes a security review gate distinct from ordinary dependency scanning before execution is permitted; this gate is not satisfied merely because the generating Agent's run succeeded or passed VPF. Suspect artifacts are quarantined pending review rather than deployed provisionally.

23.R RACI / Control Ownership

Table 31. Chapter 23 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve artifact acceptance/generated-code security gate	Accountable Authority Class (to be assigned)	Supply-Chain Security Owner (to be assigned)	NCIE-007 Ch.34 generated-code owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-23-1: Confirm artifact-acceptance authority and the generated-code security-gate criteria.

Traceability: NCIE-004 CI/CD; NCIE-007 Ch.34 generated-code boundary; NCIE-008 Ch.23 assurance.

Vulnerability, Patch & Security Exception Management

Define the vulnerability discovery, remediation and temporary security-exception lifecycle.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.
Upstream: NCIE-004 engineering; NCIE-008 Ch.21.

24.0 Salient Things to Note

Security exceptions are scoped and expiring, and severity does not itself create risk acceptance. This chapter routes every exception through the NCIE-008 Ch.21 lifecycle rather than allowing an engineering team to self-grant a standing exception.

24.1 Remediation Lifecycle

Discovery, triage, remediation, patching, compensating controls, and verification are ordered, traceable stages. Severity classification alone does not create risk acceptance — accepting residual risk is a distinct NCIE-008 Ch.4 decision-right act, not an automatic consequence of a severity score.

24.2 Security Exceptions Are Scoped and Expiring

A security exception follows the NCIE-008 Ch.21 exception lifecycle: scoped, time-boxed, with compensating controls, and it does not repeal the underlying security policy (EXCEPTION APPROVAL ≠ POLICY REPEAL). Expiry triggers mandatory re-assessment, not automatic renewal.

24.R RACI / Control Ownership

Table 32. Chapter 24 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve remediation governance/risk-acceptance authority	Accountable Authority Class (to be assigned)	Vulnerability Management Owner (to be assigned)	NCIE-008 Ch.21 exception owner	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-24-1: Confirm remediation-governance authority and the risk-acceptance authority for unpatched vulnerabilities.

Traceability: NCIE-004 engineering; NCIE-008 Ch.21 exception/waiver/risk-acceptance governance.

Resilience, Recovery & Security Reconciliation

Define secure recovery after outage, restore or incident: backup security, restore trust, credential/key rotation and current-state reconciliation.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 resilience; NCIE-006 recovery; NCIE-007 recovery.

25.0 Salient Things to Note

Restore reconciles current identities, authorization, Agent/model/Tool eligibility, secrets and security state — it never recreates stale authority. A restored session or cache that still carries pre-incident privilege is treated here as a reconciliation failure, not a convenience.

25.1 Recovery Is Not Reauthorization

RECOVERY ≠ REAUTHORIZATION. Restoring from backup or failover reconciles current identities, authorization, Agent/model/Tool eligibility, secrets and security state against present reality — it does not recreate the authority, session or privilege state that existed at backup time.

25.2 Compromised Backups and Secure Failover

A backup or failover target of uncertain integrity is treated as compromised until verified; restoring from it without verification is prohibited. Credential and key rotation follows any recovery event that could have exposed them, rather than being deferred to routine rotation schedule.

25.R RACI / Control Ownership

Table 33. Chapter 25 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve security-recovery acceptance/compromised-state handling	Accountable Authority Class (to be assigned)	Resilience/Recovery Security Owner (to be assigned)	NCIE-004/006/007 recovery owners	Assurance/Audit (NCIE-008)

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-25-1: Confirm security-recovery acceptance authority and the compromised-backup/compromised-state handling process.

Traceability: NCIE-004 resilience; NCIE-006 recovery; NCIE-007 recovery doctrine.

Security Testing, Assurance & Adversarial Validation

Define security verification classes — without duplicating detailed NCIE-016 test case authoring — covering IAM bypass through supply-chain compromise.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-004 testing; NCIE-007 adversarial evaluation; NCIE-008 assurance; NCIE-016 downstream.

26.0 Salient Things to Note

Every named test class is mandatory to specify, and TEST SPECIFIED ≠ TEST EXECUTED throughout — no test in Table 34 is marked passed, executed, or even implemented, because none has run. This is the same status discipline NCIE-007 Ch.32 and NCIE-008 Ch.26 already apply.

26.1 Test Classes

Nine test classes are specified: IAM bypass, privilege escalation, cross-context leakage, sandbox escape, prompt injection, DLP bypass, Tool misuse, recovery/revocation failure, and supply-chain compromise. Each traces to the chapter(s) whose controls it verifies.

Table 34. Security test-class specification.

Test ID	Test Class	Verifies	Status
SEC-T1	IAM Bypass	Chapters 5-6: authentication/authorization cannot be bypassed or confused-deputy'd	TEST SPECIFIED
SEC-T2	Privilege Escalation	Chapters 8-9: ordinary/emergency elevation cannot exceed its scoped, time-boxed grant	TEST SPECIFIED
SEC-T3	Cross-Context Leakage	Chapter 17: retrieval/Context isolation across User/Room/Investigation boundaries holds under adversarial query	TEST SPECIFIED
SEC-T4	Sandbox Escape	Chapter 14: Agent Runtime sandbox boundary cannot be breached from within a Run	TEST SPECIFIED
SEC-T5	Prompt Injection	Chapter 17/NCIE-007 Ch.25: untrusted content cannot become system/policy authority	TEST SPECIFIED
SEC-T6	DLP Bypass	Chapter 18: classification/DLP controls hold across all five data paths in Table 25	TEST SPECIFIED
SEC-T7	Tool Misuse	Chapter 16: Tool invocation cannot proceed without current actor/action/target authorization	TEST SPECIFIED
SEC-T8	Recovery/Revocation	Chapters 10, 22, 25: revoked	TEST SPECIFIED

	Failure	credentials and restored state cannot reactivate stale authority	
SEC-T9	Supply-Chain Compromise	Chapter 23: unverified or tampered artifacts are quarantined rather than deployed	TEST SPECIFIED

26.2 Test-Status Integrity

Specifying a test is not executing it (TEST SPECIFIED ≠ TEST EXECUTED). For every test above: IMPLEMENTATION EVIDENCE AVAILABLE = NO; TEST EXECUTED = NO; TEST PASSED = N/A; OPERATIONAL/HUMAN ACCEPTANCE = PENDING. Detailed test-case authoring, automation and execution are downstream in NCIE-016; this chapter fixes what must be tested, not that it has been.

26.R RACI / Control Ownership

Table 35. Chapter 26 RACI / control ownership.

Security Function	Accountable (NCIE-008)	Responsible (Security)	Consulted	Informed
Approve test acceptance authority/independence	Accountable Authority Class (to be assigned)	Security Test Owner (to be assigned)	Assurance/Audit (NCIE-008, independent per Ch.6 SoD)	NCIE-016 downstream owner

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-26-1: Confirm test acceptance authority, tester independence and the required test classes in Table 34.

Traceability: NCIE-004 testing; NCIE-007 adversarial evaluation; NCIE-008 assurance; NCIE-016 downstream.

Human Review Register & Open Security Decisions

Consolidate every unresolved security/IAM/Zero-Trust decision exposed across Chapters 1-26 and Chapter 28 into one register: deduplicated, consistently classified, each stating precisely what it blocks. No item here manufactures closure of a decision the approved upstream chain, the approved NCIE-008 governance layer, or the approved NCIE-009 Skeletal v0.1 does not itself settle.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: NCIE-008 Human Review Register, plus security-specific unresolved items from Chapters 1-26.

27.0 Salient Things to Note

Do not invent answers; Blocking scope must be precise and aligned with NCIE-008 authority; deduplicate identical upstream governance questions.

27.1 Purpose

This register exists so that no unresolved security decision is silently settled by expansion prose, and so that no chapter's own Human Review Focus item is left outside the register it is meant to feed — a defect found and corrected in the companion NCIE-008 document's initial build. Every item from Chapters 1-26 below was extracted programmatically from that chapter's own Human Review Focus section (§27.4). Chapter 27's own item (HR9-27-1) and Chapter 28's own item (HR9-28-1) are each defined once as a fixed value and rendered identically both here and in their own chapter's Human Review Focus bullet, so neither can be omitted from the register or drift from the bullet that also states it.

27.2 Summary

Table 36. Human Review Register summary (mechanically computed).

Classification	Count
INSTITUTIONAL CONFIRMATION REQUIRED	24
RESOLVED BY UPSTREAM BASELINE	1
SECURITY/SOVEREIGNTY CONFIRMATION REQUIRED	3
Total	28
— Blocking	24
— Non-Blocking	4

27.3 Complete Register

Table 37. Complete Human Review Register.

Review ID	Source Chapter	Question	Classification	Blocking Scope	Upstream NCIE-008 Cross-Reference	Status
HR9-1-1	Chapter 1	Confirm the acceptance authority for NCIE-009 as a whole and the security-architecture sign-off authority for each of its 28 chapters.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm the acceptance authority for NCIE-009 as a whole and the security-architecture sign-off authority for each of its 28 chapters.	NCIE-008 HR8-10-1 (acceptance/chapter sign-off authority) — same institutional question, instantiated for NCIE-009;	Open

resolving HR8-10-1 for the NCIE-series pattern resolves this item too.

HR9-2-1	Chapter 2	Approve institutional risk appetite and confirm any unresolved threat assumptions not settled by the approved upstream chain.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Approve institutional risk appetite and confirm any unresolved threat assumptions not settled by the approved upstream chain.	N/A — distinct security decision	Open
HR9-3-1	Chapter 3	Confirm the authoritative identity source for each principal class and any institution-specific identity classes not covered above.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm the authoritative identity source for each principal class and any institution-specific identity classes not covered above.	N/A — distinct security decision	Open
HR9-4-1	Chapter 4	Approve the required proofing strength per identity class and the institutional enrollment authority.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Approve the required proofing strength per identity class and the institutional enrollment authority.	N/A — distinct security decision	Open
HR9-5-1	Chapter 5	Approve assurance levels and step-up triggers per Table 7; no specific factor set or numeric threshold is adopted by default absent a sourced institutional decision.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Approve assurance levels and step-up triggers per Table 7; no specific factor set or numeric threshold is adopted by default absent a sourced institutional decision.	N/A — distinct security decision	Open
HR9-6-1	Chapter 6	Approve the authorization policy model in Table 9 and confirm unresolved role/attribute mappings.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Approve the authorization policy model in Table 9 and confirm unresolved role/attribute mappings.	N/A — distinct security decision	Open
HR9-7-1	Chapter 7	Confirm the permitted and prohibited delegation classes in Table 11.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm the permitted and prohibited delegation classes in Table 11.	N/A — distinct security decision	Open
HR9-8-1	Chapter 8	Confirm privileged-access approval authority and	INSTITUTIONAL CONFIRMATION	Confirm privileged-access approval authority and	N/A — distinct security decision	Open

		classes in Table 13.	REQUIRED (Blocking)	classes in Table 13.		
HR9-9-1	Chapter 9	Confirm break-glass authority, eligible emergency classes and post-event review rules in Table 15.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm break-glass authority, eligible emergency classes and post-event review rules in Table 15.	N/A — distinct security decision	Open
HR9-10-1	Chapter 10	Approve session assurance/expiry policy and credential classes; no specific duration is adopted by default absent a sourced institutional decision.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Approve session assurance/expiry policy and credential classes; no specific duration is adopted by default absent a sourced institutional decision.	N/A — distinct security decision	Open
HR9-11-1	Chapter 11	Confirm secrets/key custodial authority and the exception policy for secret handling.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm secrets/key custodial authority and the exception policy for secret handling.	N/A — distinct security decision	Open
HR9-12-1	Chapter 12	Approve cryptographic policy (algorithm families, key-separation tiers) where not already fixed by an approved upstream source; does not block use of the conceptual protections already stated above.	INSTITUTIONAL CONFIRMATION REQUIRED (Non-Blocking)	Non-blocking — does not gate chapter-level security operation	N/A — distinct security decision	Open
HR9-13-1	Chapter 13	Confirm network trust zones, Agent/external egress classes and exception-granting authority.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm network trust zones, Agent/external egress classes and exception-granting authority.	N/A — distinct security decision	Open
HR9-14-1	Chapter 14	Confirm Agent Factory security ceilings and the generated-code security-review requirement before any generated-code Agent path is activated.	SECURITY/SOVEREIGNTY CONFIRMATION REQUIRED (Blocking)	Confirm Agent Factory security ceilings and the generated-code security-review requirement before any generated-code Agent path is activated.	N/A — distinct security decision	Open
HR9-15-1	Chapter 15	Confirm provider-security acceptance criteria	SECURITY/SOVEREIGNTY CONFIRMATION	Confirm provider-security acceptance criteria	N/A — distinct security decision	Open

		and any restricted data/provider combinations that require additional residency or sovereignty confirmation.	REQUIRED (Blocking)	and any restricted data/provider combinations that require additional residency or sovereignty confirmation.		
HR9-16-1	Chapter 16	Confirm high-risk Tool classes and the security approval requirements for each.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm high-risk Tool classes and the security approval requirements for each.	N/A — distinct security decision	Open
HR9-17-1	Chapter 17	Confirm the security-approval requirements for any cross-context exception (NCIE-008 Ch.17 §17.2).	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm the security-approval requirements for any cross-context exception (NCIE-008 Ch.17 §17.2).	N/A — distinct security decision	Open
HR9-18-1	Chapter 18	Confirm DLP policy classes, disclosure authorities and exceptions in Table 25.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm DLP policy classes, disclosure authorities and exceptions in Table 25.	N/A — distinct security decision	Open
HR9-19-1	Chapter 19	Confirm protected-identity access classes and the escalation authority for privacy-sensitive requests.	SECURITY/SOVEREIGNTY CONFIRMATION REQUIRED (Blocking)	Confirm protected-identity access classes and the escalation authority for privacy-sensitive requests.	N/A — distinct security decision	Open
HR9-20-1	Chapter 20	Confirm security-log retention and access policy and the interface to NCIE-008 Ch.23 assurance; does not block ongoing security-event capture in the interim.	INSTITUTIONAL CONFIRMATION REQUIRED (Non-Blocking)	Non-blocking — does not gate chapter-level security operation	N/A — distinct security decision	Open
HR9-21-1	Chapter 21	Confirm monitoring ownership, escalation classes and severity governance; does not block the detection classes already specified in the interim.	INSTITUTIONAL CONFIRMATION REQUIRED (Non-Blocking)	Non-blocking — does not gate chapter-level security operation	N/A — distinct security decision	Open
HR9-22-1	Chapter 22	Confirm incident command authority, notification	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm incident command authority, notification	N/A — distinct security decision	Open

		obligations and containment rights.		obligations and containment rights.		
HR9-23-1	Chapter 23	Confirm artifact-acceptance authority and the generated-code security-gate criteria.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm artifact-acceptance authority and the generated-code security-gate criteria.	N/A — distinct security decision	Open
HR9-24-1	Chapter 24	Confirm remediation-governance authority and the risk-acceptance authority for unpatched vulnerabilities.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm remediation-governance authority and the risk-acceptance authority for unpatched vulnerabilities.	N/A — distinct security decision	Open
HR9-25-1	Chapter 25	Confirm security-recovery acceptance authority and the compromised-backup/compromised-state handling process.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm security-recovery acceptance authority and the compromised-backup/compromised-state handling process.	N/A — distinct security decision	Open
HR9-26-1	Chapter 26	Confirm test acceptance authority, tester independence and the required test classes in Table 34.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Confirm test acceptance authority, tester independence and the required test classes in Table 34.	N/A — distinct security decision	Open
HR9-27-1	Chapter 27	Review this consolidated register and decide, for each Blocking item, whether it must be resolved before NCIE-009 v1.0 may be approved or may instead remain open under an interim security default.	INSTITUTIONAL CONFIRMATION REQUIRED (Blocking)	Review this consolidated register and decide, for each Blocking item, whether it must be resolved before NCIE-009 v1.0 may be approved or may instead remain open under an interim security default.	N/A — distinct security decision	Open
HR9-28-1	Chapter 28	Approve the NCIE-009 skeletal structure and authorize controlled full expansion — already satisfied by the approved NCIE-009 Skeletal v0.1 and the production directive that	RESOLVED BY UPSTREAM BASELINE (Non-Blocking)	Non-blocking — does not gate chapter-level security operation	N/A — distinct security decision	Resolved by upstream baseline

authorized this v1.0
expansion;
preserved here as
historical record,
not a live open
item.

27.4 Mechanical Verification

26 of these 28 items were recomputed programmatically from the Human Review Focus bullet text of Chapters 1-26 rather than assembled by hand. The remaining 2 items are HR9-27-1 (this chapter's own item) and HR9-28-1 (Chapter 28's own item), each defined once and rendered identically in both this table and their own chapter's Human Review Focus bullet. 0 duplicate Review IDs; 0 orphan Human Review items — every Human Review ID appearing anywhere in this specification is reconciled into this register.

27.5 Upstream Deduplication (Directive Item 51)

One item, HR9-1-1, restates an institutional question NCIE-008 has already opened as HR8-10-1 (acceptance authorities for each NCIE-series document and chapter-level sign-off); Table 37 cross-references it rather than treating it as an independent open question, per directive item 51. No other NCIE-009 item was found to duplicate an existing NCIE-008 governance question — each remaining item concerns a security-specific decision (an assurance level, a threshold, a control-ownership assignment, or a test/acceptance authority) that NCIE-008 does not itself resolve.

27.6 Blocking Scope Discipline

Each Blocking item states exactly what it blocks — a specific control default, threshold, ownership assignment or acceptance authority — rather than implying the whole of NCIE-009 or the whole approved upstream chain is blocked. Non-Blocking items are explicitly proposed defaults or confirmations that do not gate the corresponding chapter's security operation in the interim.

Human Review Focus

- [INSTITUTIONAL CONFIRMATION REQUIRED] (Blocking) HR9-27-1: Review this consolidated register and decide, for each Blocking item, whether it must be resolved before NCIE-009 v1.0 may be approved or may instead remain open under an interim security default.

Traceability: All chapters above (mechanically reconciled register); NCIE-008 Human Review Register.

Traceability, Acceptance & Downstream Handover

Close traceability to the approved NCIE-001-008 foundation and the approved NCIE-009 Skeletal v0.1; define acceptance criteria and the downstream handover to NCIE-011/012/014/015/016.

Status: IN DEVELOPMENT — FOR HUMAN REVIEW.

Upstream: Approved NCIE-001-008 foundation; NCIE-009 Skeletal v0.1.

28.0 Salient Things to Note

Skeleton approval authorizes expansion only. Security-architecture acceptance under this chapter does not itself resolve open NCIE-008 governance decisions and does not prove any control is implemented — Table 39 fixes ownership hooks, not deployment status.

28.1 Traceability Matrix

Every chapter of this document traces to an approved upstream authority or to the approved NCIE-009 Skeletal v0.1 itself. No chapter states a security requirement without an identifiable source.

Table 38. Full traceability matrix.

NCIE-009 Chapter	Primary Upstream Authority	Relationship
Chapter 1	NCIE-002 Ch.4/Ch.24; NCIE-004; NCIE-006/007; NCIE-008 Ch.1/Ch.4	Security mandate/boundary
Chapter 2	NCIE-002 Zero Trust; NCIE-004; NCIE-007 isolation	Security doctrine/threat model
Chapter 3	NCIE-003; NCIE-006/007; NCIE-008 Ch.3	Identity taxonomy
Chapter 4	NCIE-005 protected identity; NCIE-008 governance	Identity lifecycle
Chapter 5	NCIE-002/004; NCIE-008 decision rights	Authentication architecture
Chapter 6	NCIE-002; NCIE-006 Ch.25; NCIE-007 Ch.14; NCIE-008	Authorization architecture
Chapter 7	NCIE-006/007 delegation; NCIE-008 delegation governance	Delegation/effective principal
Chapter 8	NCIE-006 admin/content boundary; NCIE-008 Ch.20	Privileged access management
Chapter 9	NCIE-008 Ch.20/22; NCIE-006 break-glass	Break-glass/emergency access
Chapter 10	NCIE-004 IAM/secrets; NCIE-006/007	Session/token/credential security
Chapter 11	NCIE-004 secrets; NCIE-008 policy/SoD	Secrets/key governance interface
Chapter 12	NCIE-003 sensitive fields; NCIE-004; NCIE-006	Cryptography/data protection
Chapter 13	NCIE-004 network; NCIE-007 egress	Network Zero Trust
Chapter 14	NCIE-004 Agent Factory; NCIE-006 Context; NCIE-007 synthesis	Agent runtime/sandbox security
Chapter 15	NCIE-007 Model Gateway; NCIE-006 Context; NCIE-008 model	Model/provider security

	governance	
Chapter 16	NCIE-004 Tool Gateway; NCIE-007 Tools; NCIE-008 Ch.14	Tool/connector security
Chapter 17	NCIE-006 v1.2; NCIE-007 Ch.17; NCIE-008 Ch.17	Context/Memory/retrieval security
Chapter 18	NCIE-003 classification; NCIE-005; NCIE-006; NCIE-008	DLP/disclosure controls
Chapter 19	NCIE-003 protected fields; NCIE-005/006; NCIE-008 Ch.20	Protected identity/privacy security
Chapter 20	NCIE-003 provenance; NCIE-006; NCIE-007; NCIE-008 Ch.23	Security logging/audit/provenance
Chapter 21	NCIE-004; NCIE-007; NCIE-008 Ch.23	Detection/monitoring/analytics
Chapter 22	NCIE-008 Ch.22; NCIE-004; NCIE-007	Incident response/containment
Chapter 23	NCIE-004 CI/CD; NCIE-007 Ch.34; NCIE-008 Ch.23	Supply-chain/artifact security
Chapter 24	NCIE-004; NCIE-008 Ch.21	Vulnerability/patch/exception management
Chapter 25	NCIE-004 resilience; NCIE-006/007 recovery	Resilience/recovery/reconciliation
Chapter 26	NCIE-004; NCIE-007; NCIE-008; NCIE-016 downstream	Security testing/assurance
Chapter 27	All chapters above; NCIE-008 Human Review Register	Consolidated Human Review Register
Chapter 28	Approved NCIE-001-008; NCIE-009 Skeletal v0.1	Traceability/acceptance/handover

28.2 Traceability Mechanical Verification

A programmatic scan of this document confirms exactly 28 sequential 'NCIE-009 — Chapter N Expansion' labels, N = 1..28, each present exactly once, in order, with no gap, duplicate or unintended renaming (directive item 60).

28.3 Skeleton-to-Full Fidelity Verification

Every approved Chapter Purpose, Salient Things to Note, Principal Security Components, Upstream Dependencies/Authority and Human Review Focus from the approved NCIE-009 Skeletal v0.1 is substantively represented in the corresponding full chapter above (directive item 59); none is omitted, and none is conceptually inverted.

28.4 Security-Control-Ownership Matrix

A consolidated view of which chapter owns which control domain and which NCIE-008 decision-right class governs its institutional approval (directive item 48's sixth matrix), so no control domain is left without a traceable governance hook.

Table 39. Security-Control-Ownership Matrix.

Control Domain	Owning Chapter(s)	NCIE-008 Decision-Right Class	Human Review Status
Identity taxonomy/lifecycle	Ch.3-4	Registration, Acceptance	Holder — Human Review

Authentication/session/credential	Ch.5, Ch.10	Authorization, Acceptance	Holder — Human Review
Authorization/policy decision	Ch.6	Authorization	Holder — Human Review
Delegation/effective principal	Ch.7	Authorization	Holder — Human Review
Privileged access/break-glass	Ch.8-9	Authorization, Suspension	Holder — Human Review
Secrets/key/cryptography	Ch.11-12	Authorization, Exception	Holder — Human Review
Network Zero Trust	Ch.13	Authorization, Exception	Holder — Human Review
Agent runtime/sandbox	Ch.14	Registration, Suspension	Holder — Human Review
Model/provider security	Ch.15	Approval, Suspension	Holder — Human Review
Tool/connector security	Ch.16	Approval, Consequential Action	Holder — Human Review
Context/Memory/retrieval security	Ch.17	Exception	Holder — Human Review
Data classification/DLP/disclosure	Ch.18-19	Publication, Exception	Holder — Human Review
Security logging/audit/provenance	Ch.20	Acceptance	Holder — Human Review
Detection/monitoring	Ch.21	Finding (routes to)	Holder — Human Review
Incident response/containment	Ch.22	Suspension	Holder — Human Review
Supply-chain/artifact security	Ch.23	Acceptance	Holder — Human Review
Vulnerability/patch/exception	Ch.24	Exception	Holder — Human Review
Resilience/recovery	Ch.25	Acceptance	Holder — Human Review
Security testing/assurance	Ch.26	Acceptance	Holder — Human Review

28.5 Acceptance Criteria and the Unresolved-Item Gate

Full approval of NCIE-009 v1.0 requires: (a) 28/28 chapter integrity confirmed; (b) skeleton-to-full fidelity confirmed; (c) every Blocking Human Review item in Chapter 27 either resolved by an institutional decision or explicitly and knowingly deferred by the approving authority; (d) the §26.1 security test suite specified with no test falsely marked executed or passed; and (e) three-artifact consistency (this document, the Change Register and the Verification Report) confirmed. Approval of the v0.1 skeleton authorized this expansion only — it did not itself approve any control default, threshold, product/algorithm choice or ownership assignment proposed above. Security-architecture acceptance under this chapter does not resolve open NCIE-008 governance decisions, and it does not prove any control is implemented, deployed or operational.

28.6 Downstream Handover Register

NCIE-009 does not preempt detailed downstream specification. The table below states what is handed over and what remains downstream.

Table 40. Downstream handover register.

Downstream Document	What NCIE-009 Hands Over
NCIE-011 (APIs)	Authentication/authorization contract requirements (Ch.5-6) and Tool/connector security contracts (Ch.16) for any API surface; no API design is specified here.
NCIE-012 (UX)	Step-up/reauthentication and break-glass user-facing requirements (Ch.5, Ch.9) for detailed UX design; no UX is specified here.
NCIE-014 (physical storage)	Logical secrets/key, cryptographic and log-retention requirements (Ch.11-12, Ch.20); no physical system or database is selected here.
NCIE-015 (operations)	Security operational responsibilities (Table 2 and per-chapter RACI/control-ownership tables) for handoff into operational runbooks; no runbook is specified here.
NCIE-016 (detailed testing)	The 9 security test classes specified in §26.1 (Table 34); detailed test cases, execution and automation remain downstream in NCIE-016 — this document specifies the tests, not their execution.

28.7 Readiness and Final Disposition

NCIE-009 Security, IAM & Zero-Trust Architecture v1.0 — Full Expansion of Approved Skeletal v0.1 — is READY FOR HUMAN REVIEW. It is NOT marked Approved. The approved v0.1 skeleton remains historically preserved as the expansion architecture; every proposed control default, threshold, ownership assignment and product/algorithm choice deferred in Chapters 1-26 remains a proposal pending the Chapter 27 Human Review Register; every §26.1 security test remains SPECIFIED, not executed, pending NCIE-016.

Human Review Focus

- [RESOLVED BY UPSTREAM BASELINE] (Non-Blocking) HR9-28-1: Approve the NCIE-009 skeletal structure and authorize controlled full expansion — already satisfied by the approved NCIE-009 Skeletal v0.1 and the production directive that authorized this v1.0 expansion; preserved here as historical record, not a live open item.

Traceability: NCIE-001-008 approved foundation; approved NCIE-009 Skeletal v0.1.